

ラボ 2.2: 安全な ICS サイトの設計

1. はじめに

1.1. 必要なリソース

- ControlThings プラットフォーム VM

1.2. 要約

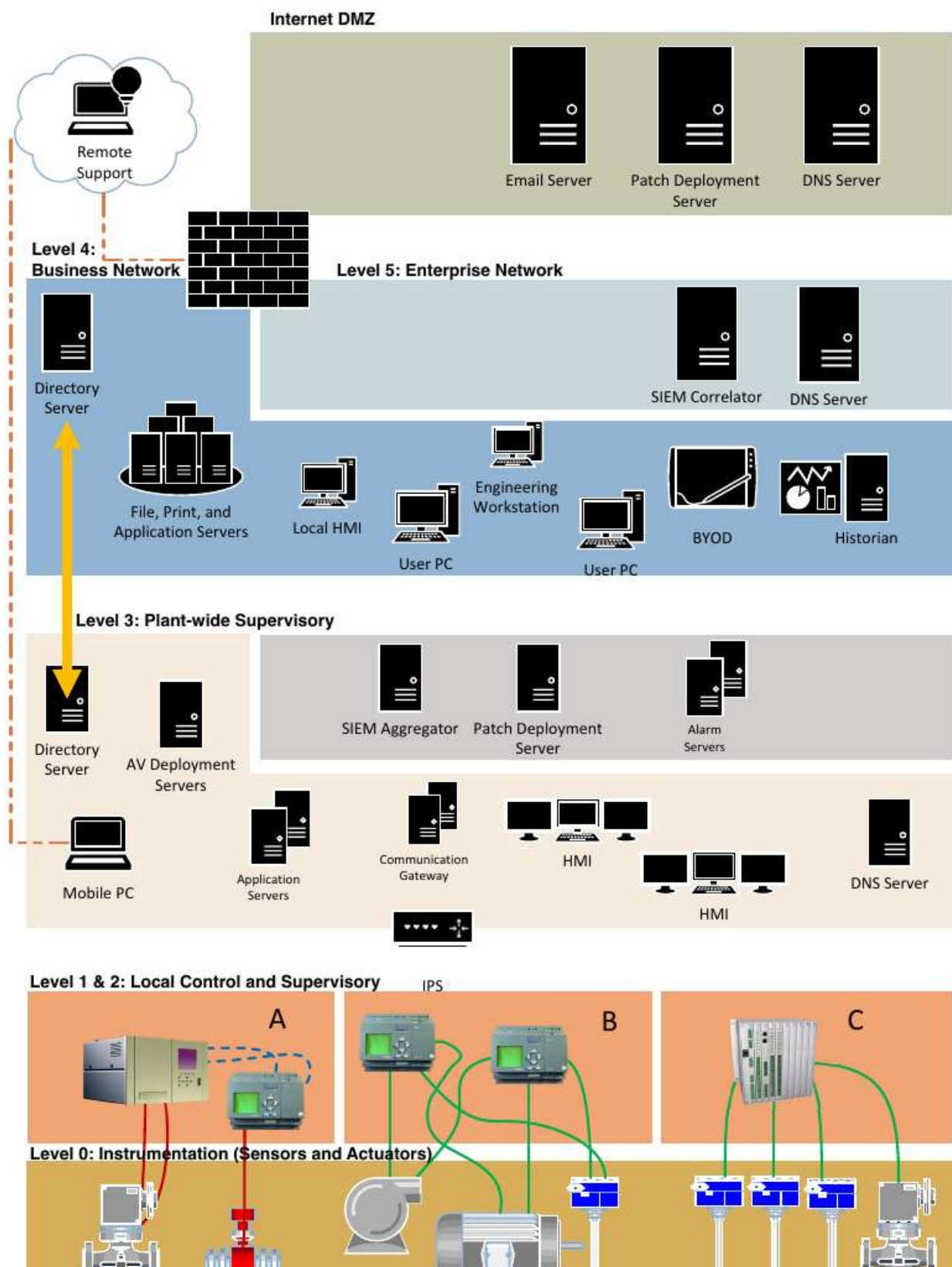
サイバーセキュリティの観点から、設計が不十分なネットワーク決定が多数含まれたDCSアーキテクチャを紹介します
先ほど見た最後の講義スライドと比較し、それに関するいくつかの質問に答えてください。

1.3. 目的

環境の設計と構築は常に楽しいものですが、既存の環境を理解し、分析し、統合し、トラブルシューティングする必要性が生じることがよくあります。このラボでは、講義で説明した設計原則を強化しながら、まさにそれを行います

2. 個人またはグループラボ

コンサルタントの立場に立って、設計のまずいICSサイトのネットワーク図を批評する準備をしましょう。第三者のコンサルタントとして働いた経験がない方も、私たちが日々経験している喜びをぜひ味わってみてください。インストラクターやTAに質問することなく、次のネットワーク図とその上のすべてのマークの意味を理解してみてください。どういたしまして。;-)





それでは、次の質問に答えてみてください。

質問

この構成はどのような運用上のリスクをもたらしますか？

質問

この構成はどのようなサイバーセキュリティ上のリスクをもたらしますか？

質問

アーキテクトがこれらの不適切なセキュリティ設計の決定を下した理由を思いつきますか？

自 考えられる回答

- 企業と監視制御ネットワークセグメントをつなぐ**ディレクトリサーバーの信頼関係**
 - ユーザー資格情報の連携を許可するように構成されている可能性があります。これにより、多数の脆弱性と脅威がプロセス制御ネットワークに持ち込まれる可能性があります。
- **エンジニアリングワークステーションと読み取り専用ヒストリアン**はビジネスネットワーク内に配置されています
 - ネットワーク通信の可用性のため、このゾーンに配置されている可能性があります。プロセス制御ネットワークへの必要な双方向および管理権限を持つ、信頼度の低いゾーンの資産です。
- 監視制御層の**モバイルPC**への直接リモートサポート
 - 環境のトラブルシューティングや調整を行うためにリモートワーカーが一時的にアクセスできるようにするために提供されている可能性があります。強力なリモートアクセス認証とVPNが不足しており、終端デバイスがネットワーク間を移動する可能性があります。
- **警報サーバー**を監視制御サポートネットワークに分離
 - ネットワーク通信の可用性と他のユーザーへの表示を可能にするために、このゾーンに配置されている可能性があります。ネットワーク通信の問題が発生すると、アラームサーバーは更新機能と表示機能を失うことになります。
- 監視制御層に含まれる**AV展開サーバーとDNS**は、上位層ネットワークへのアクセスを持つ
 - エージェントとの通信を可能にするためにこのゾーンに配置され、SATに配信されるときに変更する目的でシステムFAT用にこのように構成されている可能性があります。データの窃取やセグメントへのエクスプロイトの持ち込みに使用される可能性があります。
- ビジネスネットワークにおける**ローカルHMI**
 - ネットワーク通信の可用性のため、このゾーンに配置されている可能性があります。プロセス制御環境に影響を与える明示的な権限を持つ資産は、プロセス制御ネットワークに含まれている必要があります。
- 監視制御層とプロセス制御層の間の**IPSインライン**
 - IDSとして動作することを目的としてIPSデバイスを配置したか、重要な資産をリアルタイムで保護することを目的として意図的に配置した可能性があります。通信と全体的なプロセスに直接影響を及ぼします。

時間が許せば、ラボの後でこれらのいくつかについて議論します。